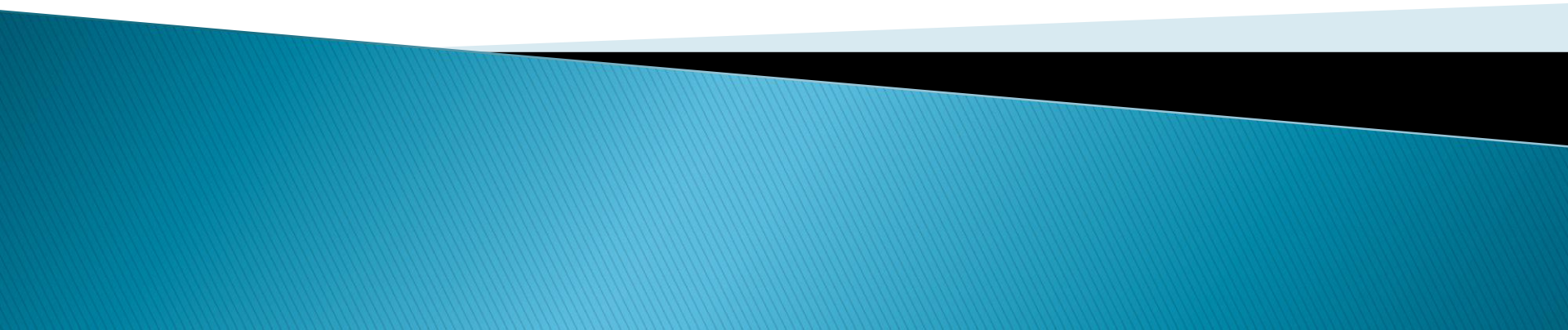


Computer Security and Cyber Law

Unit 8

Web Security and Email Security

Lecturer: Binod Chandra Shrestha



- ▶ Web security, Threats, SSL (Architecture, Handshake protocol, Handshake protocol action), overview of TLS and HTTPS, Secure Electronic Transaction overview, Dual Signature, Payment Processing, E-Mail, SMTP, PEM, PGP, Concept of Secure Email.

Web Page Security

- ▶ SQL Filtering: Filtering of web input for SQL Injection
- ▶ Encryption/Authentication: Ensuring Confidentiality, Integrity, Authenticity, Non-repudiation
- ▶ Web Protocol Protection: Protection of State
- ▶ HTML is stateless. i.e., information about the connection and data transactions have to be held by the endpoint computers. This can be exploited by a skilled hacker. Cookies and client-side scripts are two examples.
- ▶ In some cases, servers do not retain state but instead send information in a request which can be manipulated by the client before being returned. This is another form of attack.

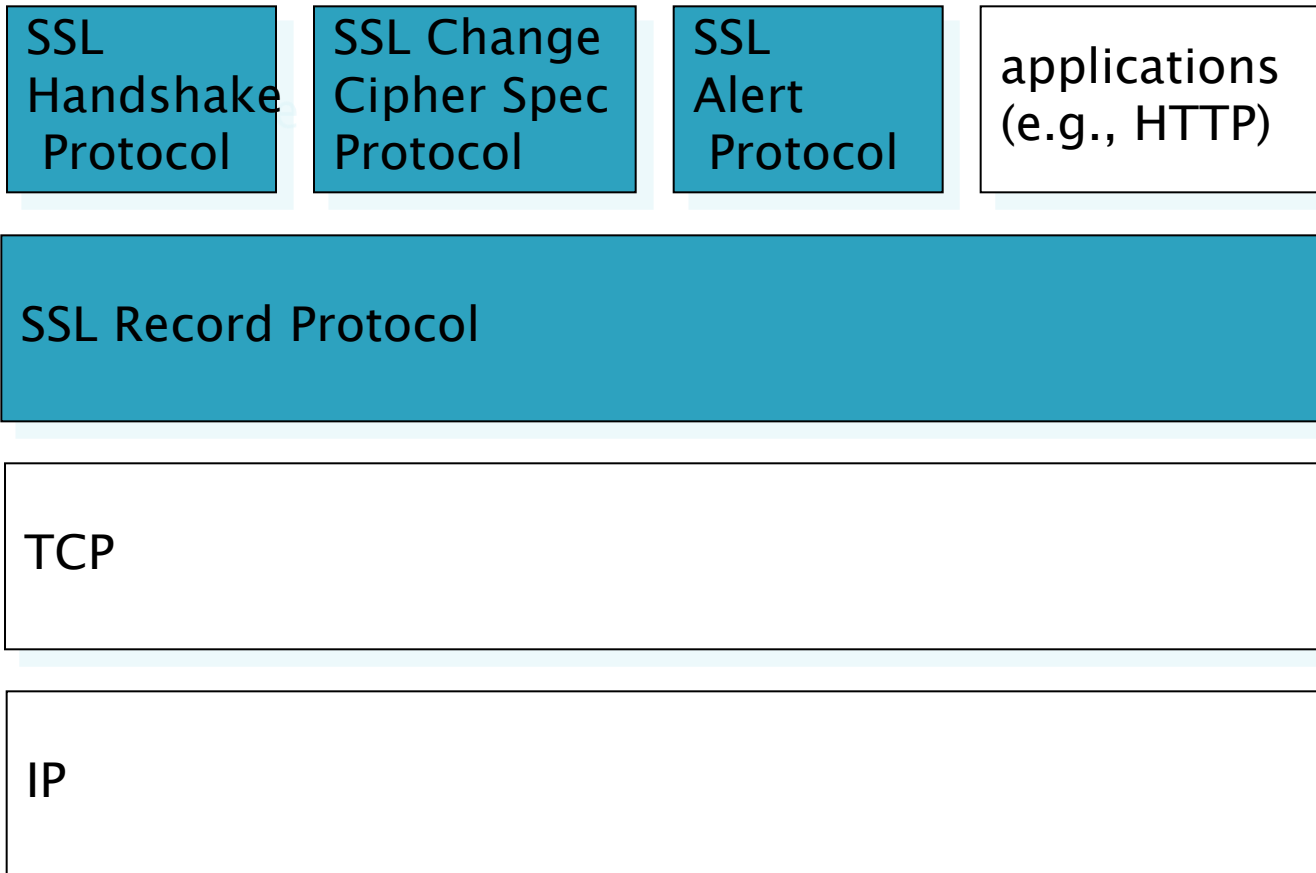
Threats

- ▶ Threats to the security of e-mail itself
 - Loss of confidentiality
 - E-mails are sent in clear over open networks
 - E-mails stored on potentially insecure clients and mail servers
 - Loss of integrity
 - No integrity protection on e-mails; body can be altered in transit or on mail server
 - Lack of data origin authentication
 - Lack of non-repudiation
 - Lack of notification of receipt

What are SSL and TLS?

- ▶ SSL – Secure Socket Layer
- ▶ TLS – Transport Layer Security
- ▶ both provide a secure transport connection between applications (e.g., a web server and a browser)
- ▶ SSL was developed by Netscape
- ▶ SSL version 3.0 has been implemented in many web browsers (e.g., Netscape Navigator and MS Internet Explorer) and web servers and widely used on the Internet
- ▶ SSL v3.0 was specified in an Internet Draft (1996)
- ▶ it evolved into TLS specified in RFC 2246
- ▶ TLS can be viewed as SSL v3.1

SSL architecture



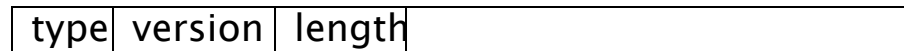
SSL components

- ▶ **SSL Handshake Protocol**
 - negotiation of security algorithms and parameters
 - key exchange
 - server authentication and optionally client authentication
- ▶ **SSL Record Protocol**
 - fragmentation
 - compression
 - message authentication and integrity protection
 - encryption
- ▶ **SSL Alert Protocol**
 - error messages (fatal alerts and warnings)
- ▶ **SSL Change Cipher Spec Protocol**
 - a single message that indicates the end of the SSL handshake

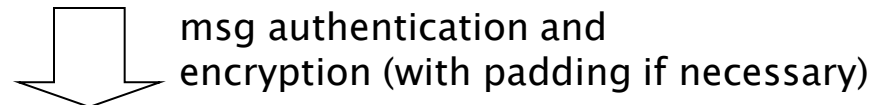
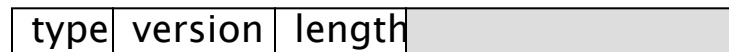
SSL Record Protocol – processing overview



SSLPlaintext



SSLCompressed



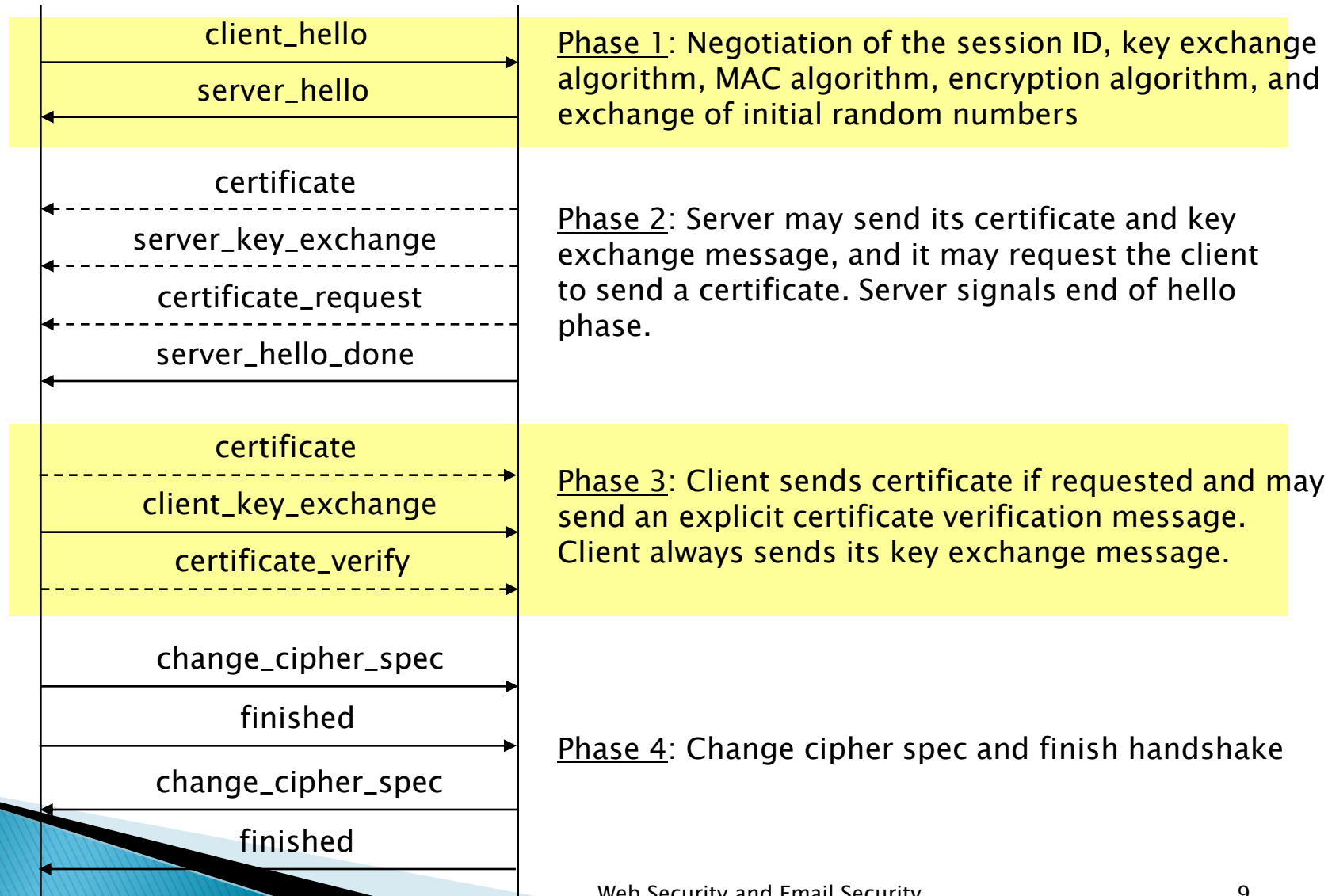
SSLCiphertext



SSL Handshake Protocol – overview

client

server



TLS vs. SSL

- ▶ version number
 - for TLS the current version number is 3.1
- ▶ MAC
 - TLS uses HMAC
 - the MAC covers the version field of the record header too
- ▶ more alert codes
- ▶ cipher suites
 - TLS doesn't support Fortezza key exchange and Fortezza encryption
- ▶ certificate_verify message
 - the hash is computed only over the handshake messages
 - in SSL the hash contained the master_secret and pads

TLS vs. SSL cont'd

- ▶ pseudorandom function PRF

- $P_hash(secret, seed) = \text{HMAC_hash}(secret, A(1) \mid seed) \mid$
 $\text{HMAC_hash}(secret, A(2) \mid seed) \mid$
 $\text{HMAC_hash}(secret, A(3) \mid seed) \mid \dots$

where

$$A(0) = seed$$

$$A(i) = \text{HMAC_hash}(secret, A(i-1))$$

- $\text{PRF}(secret, label, seed) =$
 $P_MD5(secret_left, label \mid seed) \oplus P_SHA(secret_right,$
 $label \mid seed)$

TLS vs. SSL cont'd

- ▶ finished message

PRF(master_secret,
 "client finished",
 MD5(handshake_messages) | SHA(handshake_messages))

- ▶ cryptographic computations

- pre-master secret is calculated in the same way as in SSL

- master secret:

PRF(pre_master_secret,
 "master secret",
 client_random | server_random)

- key block:

PRF(master_secret,
 "key expansion",
 server_random | client_random)

- ▶ padding before block cipher encryption

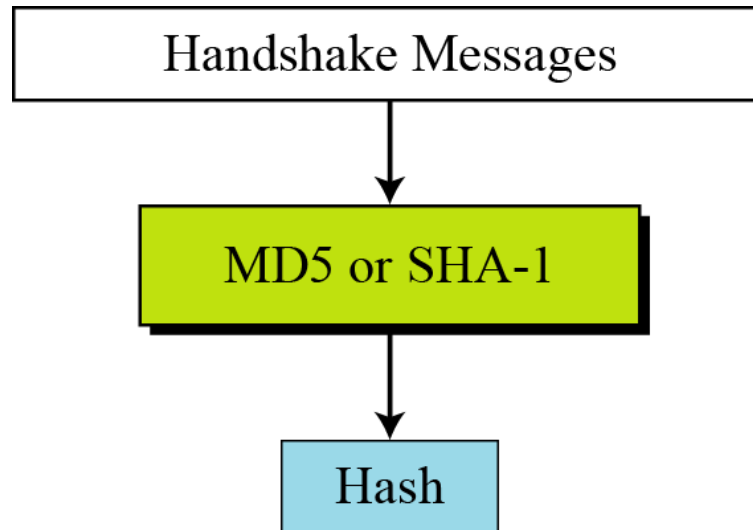
- variable length padding is allowed (max 255 padding bytes)

Transport Layer Security (TLS)

- ▶ Transport Layer Security (TLS) is a protocol that provides privacy and data integrity between two communicating applications.
- ▶ It's the most widely deployed security protocol used today, and is used for web browsers and other applications that require data to be securely exchanged over a network such as file transfer, VPN connections, instant messaging, VoIP.
- ▶ According the protocol specification, TLS is composed of two layers: the TLS record protocol and the TLS handshake protocol.
- ▶ The Record Protocol provides connection security.
- ▶ The Handshake Protocol allows the server and client to authenticate each other and to negotiate encryption algorithm and cryptographic key before any data is exchanged.

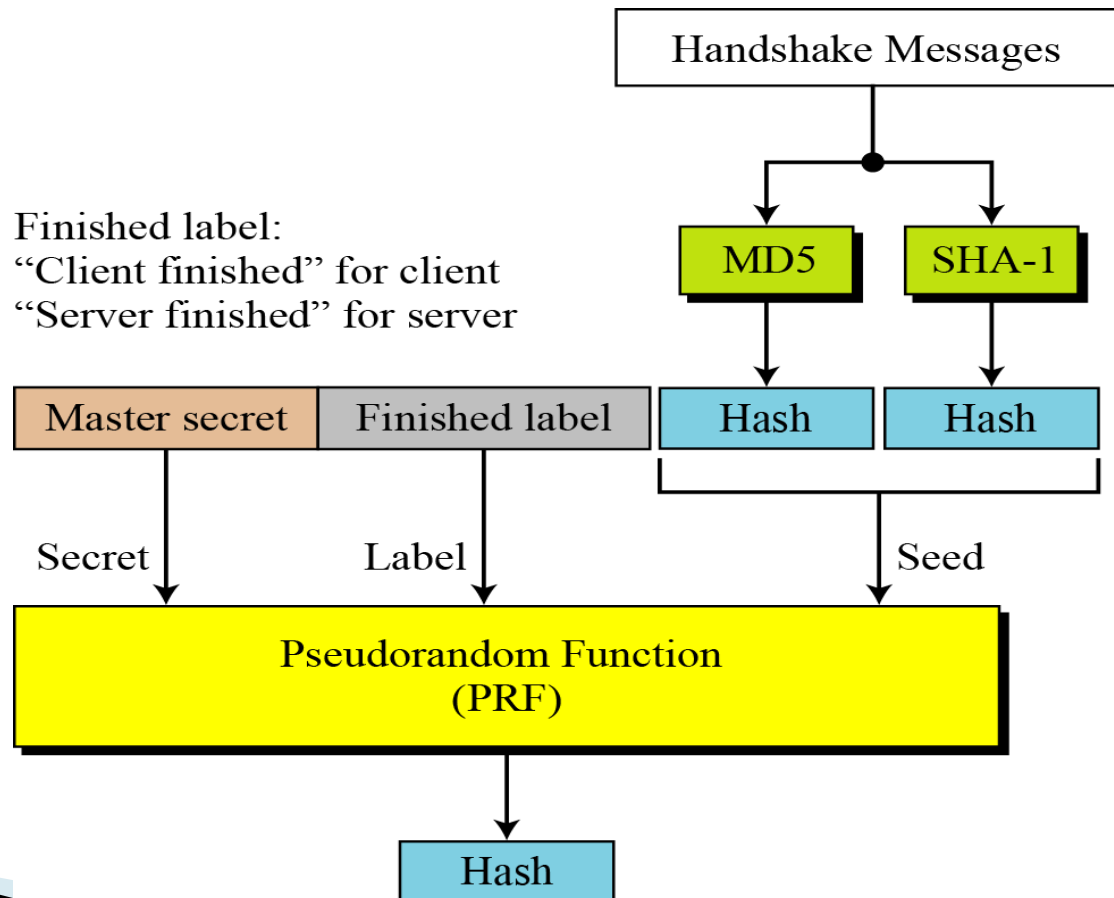
Handshake Protocol

- ▶ *Figure: Hash for CertificateVerify message in TLS*



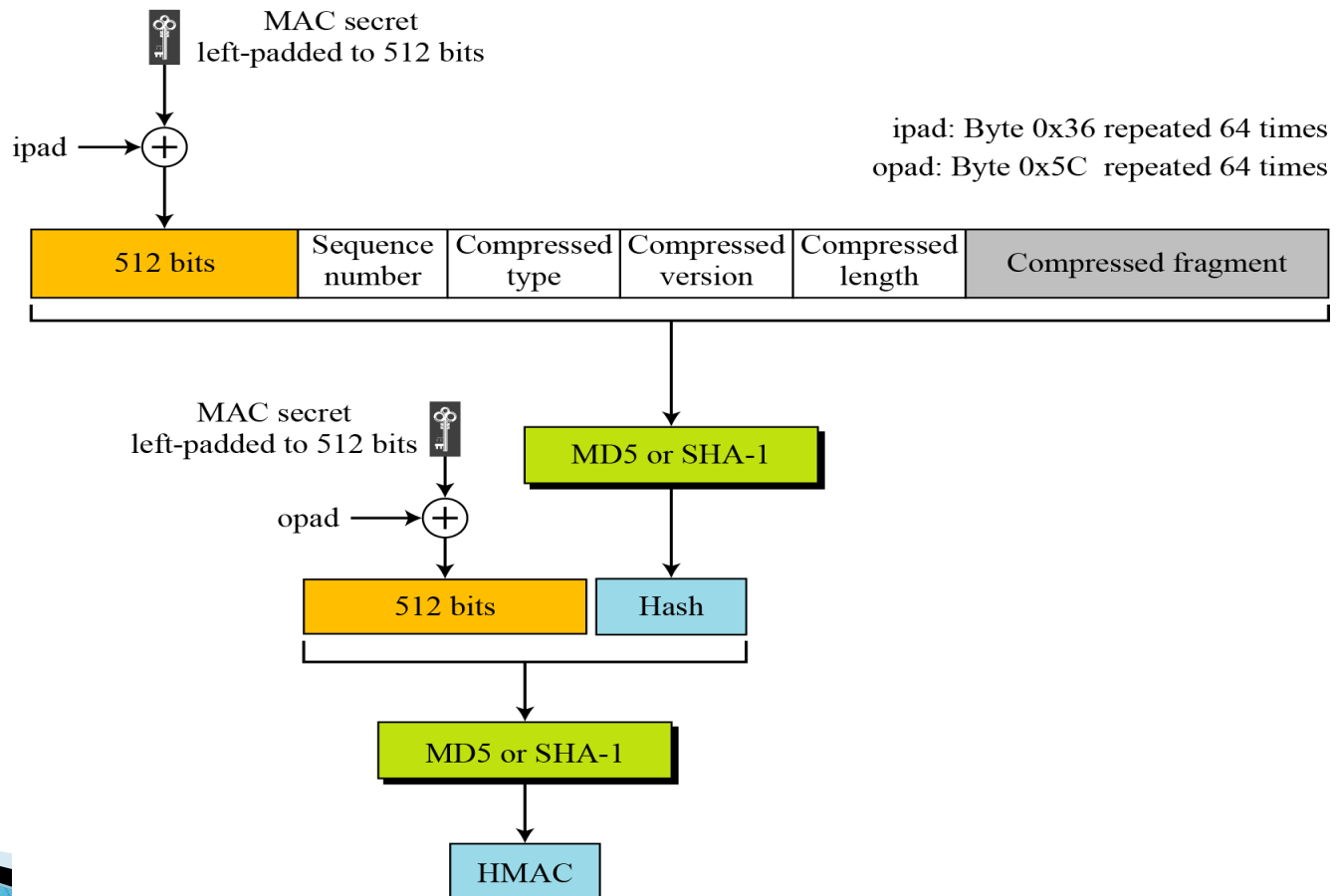
Handshake Protocol

► *Figure: Hash for Finished message in TLS*



Record Protocol

► Figure: *HMAC for TLS*



Secure-HTTP (S-HTTP)

- Secure HTTP (S-HTTP) extends the Hypertext Transfer Protocol (HTTP).
- When HTTP was developed, it was developed for a Web that was simple, that did not have dynamic graphics, that did not require, at that time, hard encryption for end-to-end transactions that have since developed.
- As the Web became popular for businesses users realized that current HTTP protocols needed more cryptographic and graphic improvements if it were to remain the e-commerce backbone it had become.

- Each S-HTTP file is either encrypted, contains a digital certificate, or both.
- S-HTTP design provides for secure communications, primarily commercial transactions, between a HTTP client and a server.
- It does this through a wide variety of mechanisms to provide for confidentiality, authentication, and integrity while separating policy from mechanism.
- HTTP messages contain two parts: the header and the body of the message. The header contains instructions to the recipients (browser and server) on how to process the message's body

- During the transfer transaction, both the client browser and the server, use the information contained in the HTTP header to negotiate formats they will use to transfer the requested information.
- The S-HTTP protocol extends this negotiation between the client browser and the server to include the negotiation for security matters. Hence S-HTTP uses additional headers for message encryption, digital certificates and authentication in the HTTP format which contains additional instructions on how to decrypt the message body (see both headers)

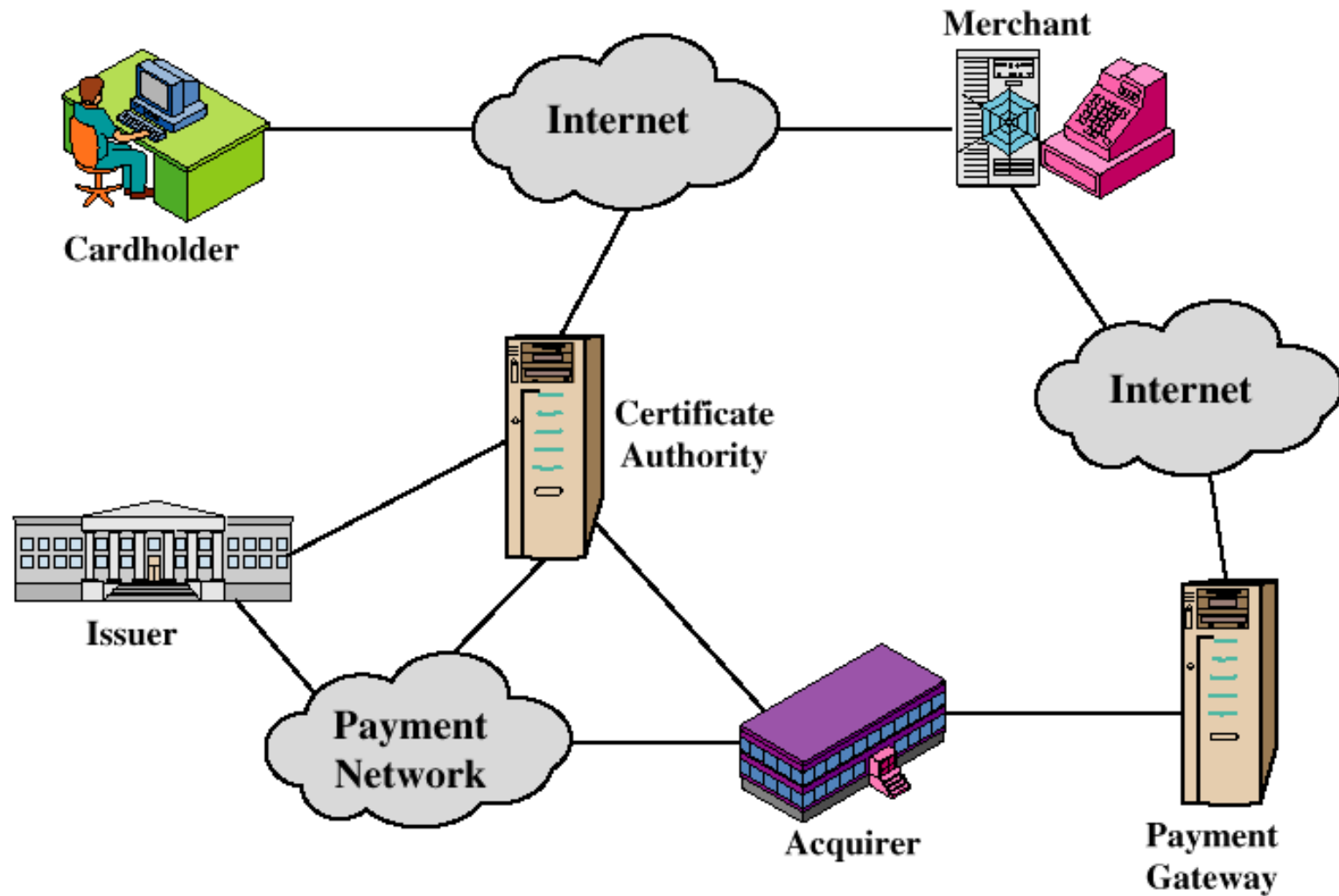
Hypertext Transfer Protocol over Secure Socket Layer (HTTPS)

- HTTPS is the use of Secure Sockets Layer (SSL) as a sub-layer under the regular HTTP in the application layer. It is also referred to as Hypertext Transfer Protocol over Secure Socket Layer (HTTPS) or HTTP over SSL, in short.
- HTTPS is a Web protocol developed by Netscape, and it is built into its browser to encrypt and decrypt user page requests as well as the pages that are returned by the Web server. HTTPS uses port 443 instead of HTTP port 80 in its interactions with the lower layer, TCP/IP

Secure Electronic Transaction (SET)

- ▶ Developed by Visa and MasterCard
- ▶ Designed to protect credit card transactions
- ▶ Confidentiality: all messages encrypted
- ▶ Trust: all parties must have digital certificates
- ▶ Privacy: information made available only when and where necessary

Participants in the SET System



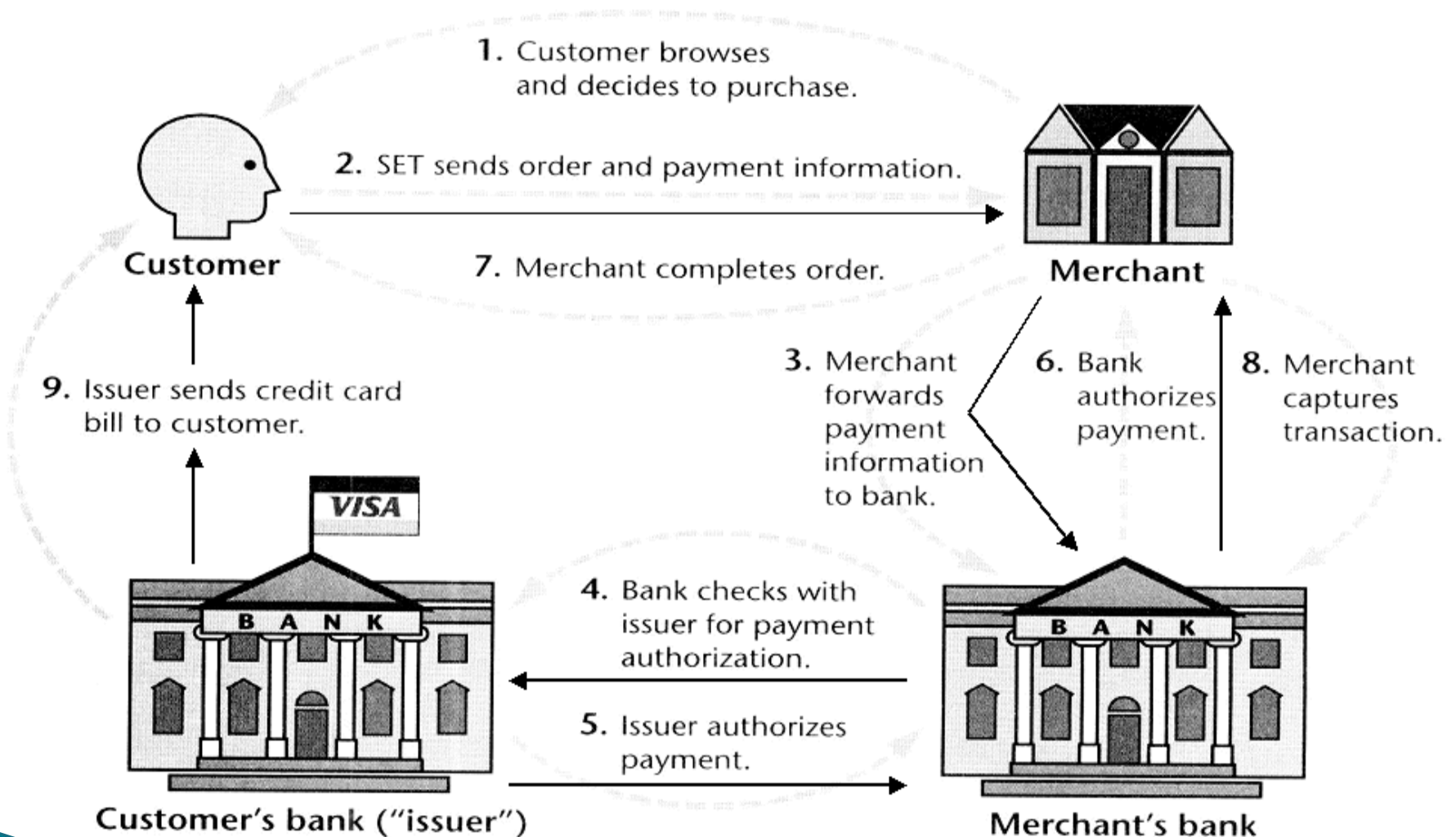
SET Business Requirements

- ▶ Provide confidentiality of payment and ordering information
- ▶ Ensure the integrity of all transmitted data
- ▶ Provide authentication that a cardholder is a legitimate user of a credit card account
- ▶ Provide authentication that a merchant can accept credit card transactions through its relationship with a financial institution

SET Business Requirements (cont'd)

- ▶ Ensure the use of the best security practices and system design techniques to protect all legitimate parties in an electronic commerce transaction
- ▶ Create a protocol that neither depends on transport security mechanisms nor prevents their use
- ▶ Facilitate and encourage interoperability among software and network providers

SET Transactions



SET Transactions

- ▶ The customer opens an account with a card issuer.
 - MasterCard, Visa, etc.
- ▶ The customer receives a X.509 V3 certificate signed by a bank.
 - X.509 V3
- ▶ A merchant who accepts a certain brand of card must possess two X.509 V3 certificates.
 - One for signing & one for key exchange
- ▶ The customer places an order for a product or service with a merchant.
- ▶ The merchant sends a copy of its certificate for verification.

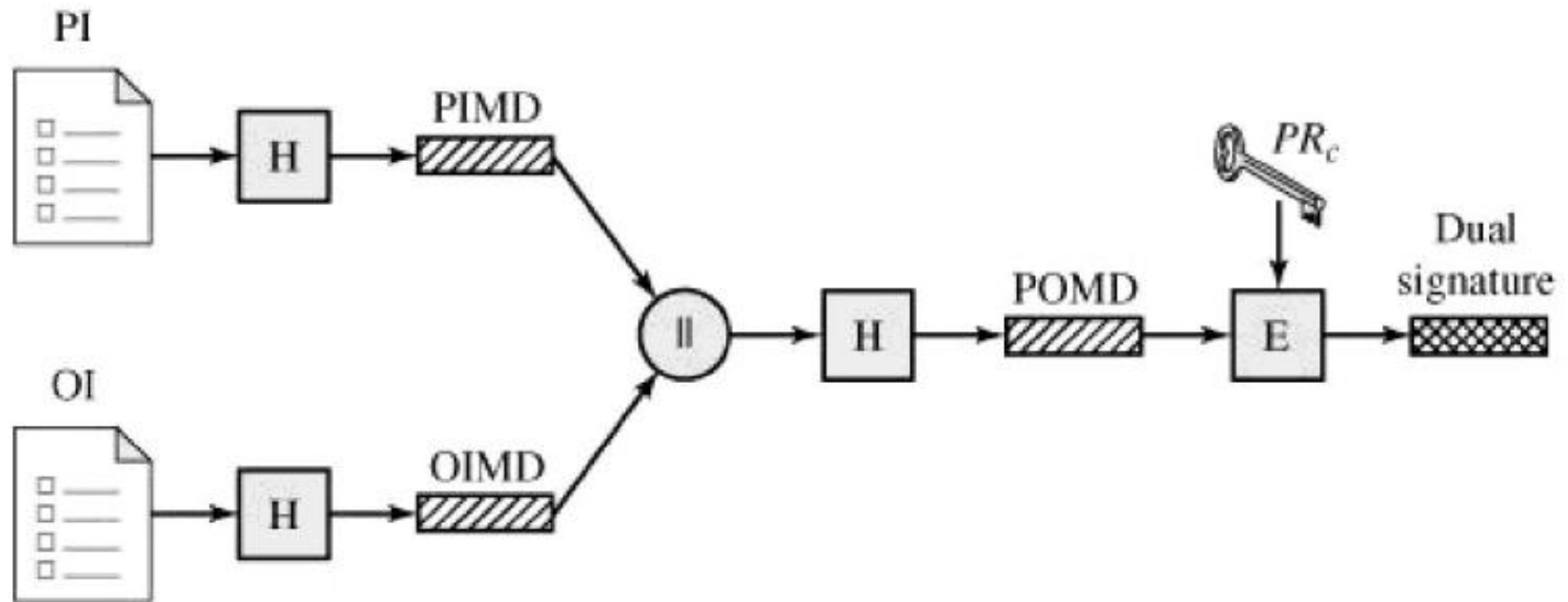
SET Transactions

- ▶ The customer sends order and payment information to the merchant.
- ▶ The merchant requests payment authorization from the payment gateway prior to shipment.
- ▶ The merchant confirms order to the customer.
- ▶ The merchant provides the goods or service to the customer.
- ▶ The merchant requests payment from the payment gateway.

Dual Signature

- ▶ An important innovation introduced in SET is the *dual signature*. The purpose of the dual signature is to link two messages that are intended for two different recipients. In this case, the customer wants to send the order information (OI) to the merchant and the payment information (PI) to the bank. The merchant does not need to know the customer's credit-card number, and the bank does not need to know the details of the customer's order. The customer is afforded extra protection in terms of privacy by keeping these two items separate. However, the two items must be linked in a way that can be used to resolve disputes if necessary. The link is needed so that the customer can prove that this payment is intended for this order and not for some other goods or service.
- ▶ The message digest (MD) of the OI and the PI are independently calculated by the customer. The dual signature is the encrypted MD (with the customer's secret key) of the concatenated MD's of PI and OI. The dual signature is sent to both the merchant and the bank. The protocol arranges for the merchant to see the MD of the PI without seeing the PI itself, and the bank sees the MD of the OI but not the OI itself. The dual signature can be verified using the MD of the OI or PI. It doesn't require the OI or PI itself. Its MD does not reveal the content of the OI or PI, and thus privacy is preserved.

Construction of Dual Signature



PI = Payment information
OI = Order information
H = Hash function (SHA-1)
|| = Concatenation

PIMD = PI message digest
OIMD = OI message digest
POMD = Payment order message digest
E = Encryption (RSA)
 PR_c = Customer's private signature key

Payment Processing

- ▶ Purchase Request
- ▶ Payment Authorization

Threats Enabled by E-mail

- ▶ Disclosure of sensitive information
- ▶ Exposure of systems to malicious code
- ▶ Denial-of-Service (DoS)
- ▶ Unauthorized accesses etc.

What are the Options

- ▶ Secure the server to client connections (easy thing first)
 - Post Office Protocol (POP), Internet Message Access Protocol (IMAP) over Secure Shell (SSH), Secure Socket Layer (SSL)
 - https access to webmail
 - Very easy to configure
 - Protection against insecure wireless access
- ▶ Secure the end-to-end email delivery
 - The PGPs of the world
 - Still need to get the other party to be PGP aware
 - Practical in an enterprise intra-network environment

Email based Attacks

- ▶ Active content attack
 - Clean up at the server (AV, Defang)
- ▶ Buffer over-flow attack
 - Fix the code
- ▶ Shell script attack
 - Scan before send to the shell
- ▶ Trojan Horse Attack
 - Use “do not automatically use the macro” option
- ▶ Web bugs (for tracking)
 - Mangle the image at the mail server

Email SPAM

- ▶ Cost to exceed \$10 billion
- ▶ SPAM filtering
 - Content based – required hits
 - White list
 - Black list
 - Defang Multipurpose Internet Mail Extensions (MIME)

Simple Mail Transfer Protocol (SMTP)

- ▶ SMTP is part of the application layer of the TCP/IP protocol. Using a process called "store and forward," SMTP moves your email on and across networks. It works closely with something called the Mail Transfer Agent (MTA) to send your communication to the right computer and email inbox.
- ▶ SMTP spells out and directs how your email moves from your computer's MTA to an MTA on another computer, and even several computers. Using that "store and forward" feature mentioned before, the message can move in steps from your computer to its destination. At each step, Simple Mail Transfer Protocol is doing its job. Lucky for us, this all takes place behind the scenes, and we don't need to understand or operate SMTP.

Privacy Enhanced Mail (PEM)

- ▶ Primary goal of PEM is to add security services for e-mail users in the internet community
- ▶ Began in 1985 as an activity of the Privacy and Security Research Group (PSRG)
- ▶ Defined in RFCs 1421/1422/1423/1424
- ▶ Consists of extensions to existing message processing software plus a key management infrastructure

PEM Security Services

- ▶ **Integrity**, which ensures a message recipient that the message has not been modified en route.
- ▶ **Authenticity**, which ensures a message recipient that a message was sent by the indicated originator.
- ▶ **Non-repudiation**, which allows a message to be forwarded to a third party, who can verify the identity of the originator.
- ▶ **Confidentiality** (optional), which ensures a message originator that the message text will be disclosed only to the designated recipients.

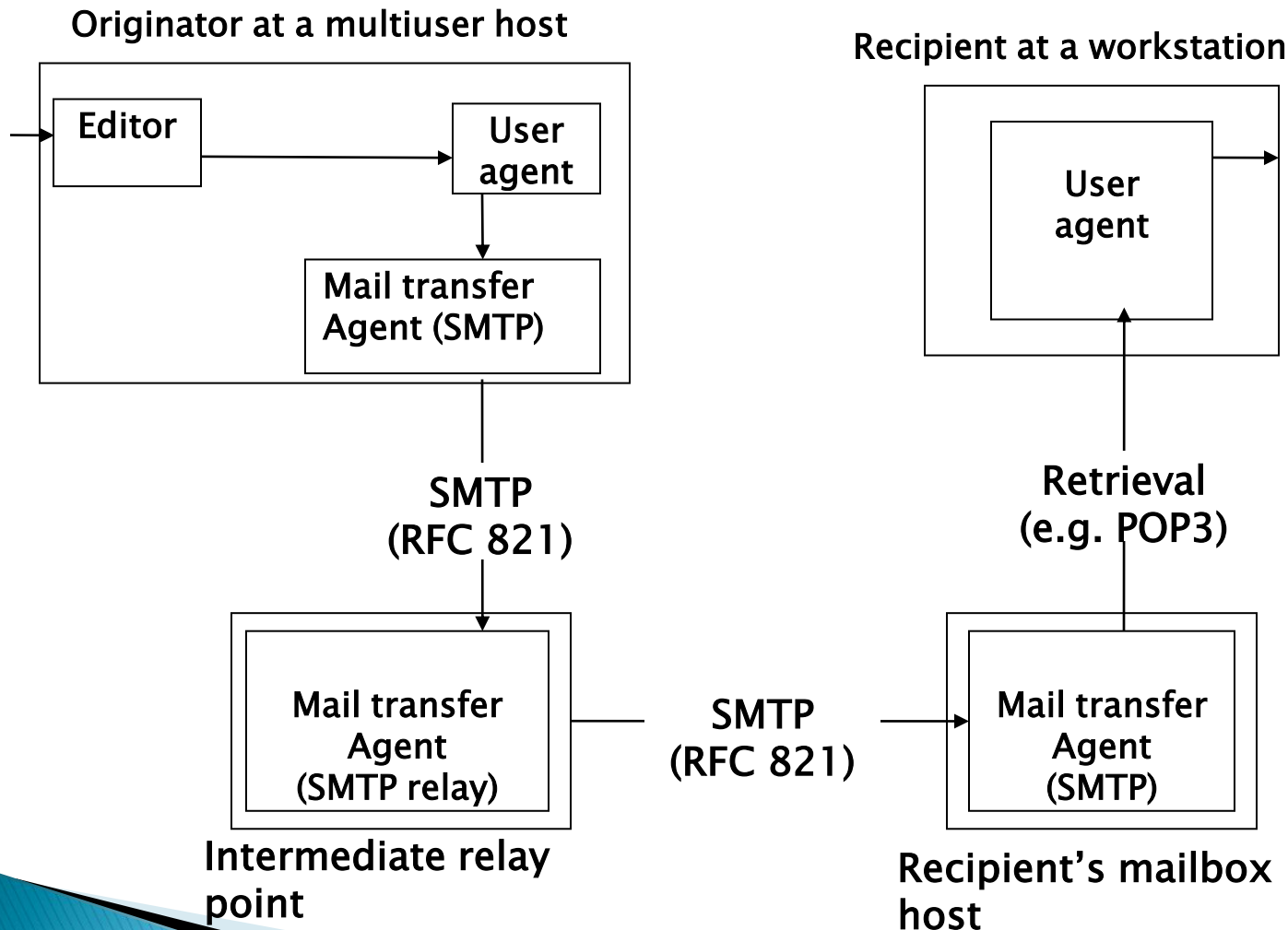
PEM Overview

- ▶ Compatible with RFC 822 message processing conventions
- ▶ Transparent to SMTP mail relays
- ▶ Uses symmetric cryptography to provide (optional) encryption of messages
- ▶ The RFCs strongly recommend the use of asymmetric cryptography (for digital signatures, certificates and encryption of the symmetric key) because of its ability to support vast distributed community of users

PEM Overview (contd.)

- ▶ The use of X.509 certificates is the base for public key management in PEM
- ▶ This certification hierarchy supports universal authentication of PEM users
- ▶ PEM can be used in a wider range of messaging environments (other than RFC 822 and SMTP)

Integration Of PEM Into Existing Mail System



PGP

- ▶ PGP=“Pretty Good Privacy”
- ▶ First released in 1991, developed by Phil Zimmerman
- ▶ Freeware: OpenPGP and variants:
- ▶ OpenPGP specified in RFC 2440 and defined by IETF OpenPGP working group.
 - www.ietf.org/html.charters/openpgp-charter.html
- ▶ Available as plug-in for popular e-mail clients, can also be used as stand-alone software.

PGP

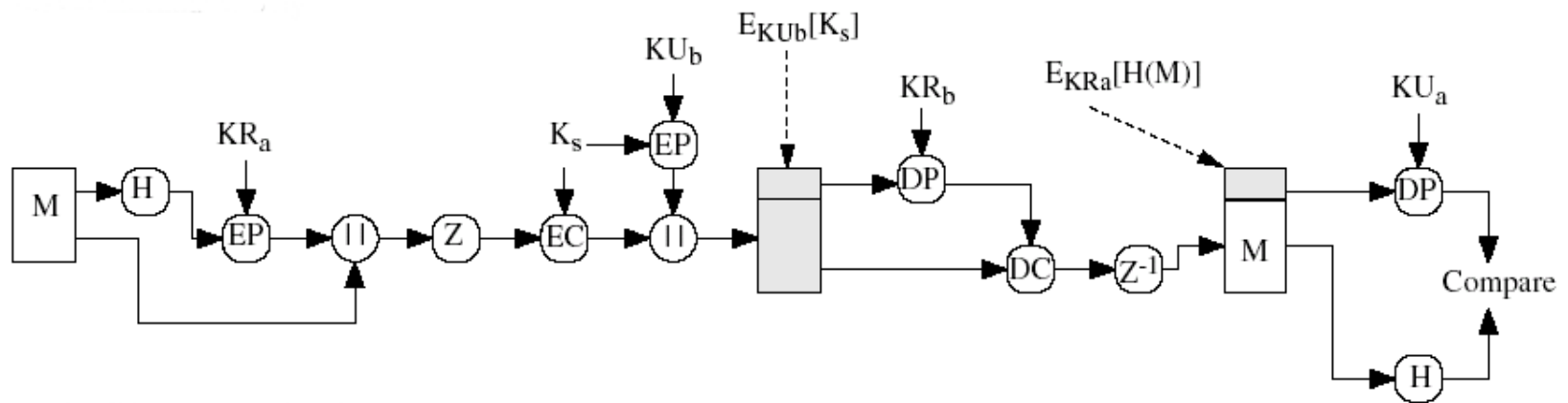
- ▶ Functionality
 - Encryption for confidentiality.
 - Signature for non-repudiation/authenticity.
- ▶ Sign before encrypt, so signatures on unencrypted data – can be detached and stored separately.
- ▶ PGP-processed data is `base64` encoded

PGP Algorithms

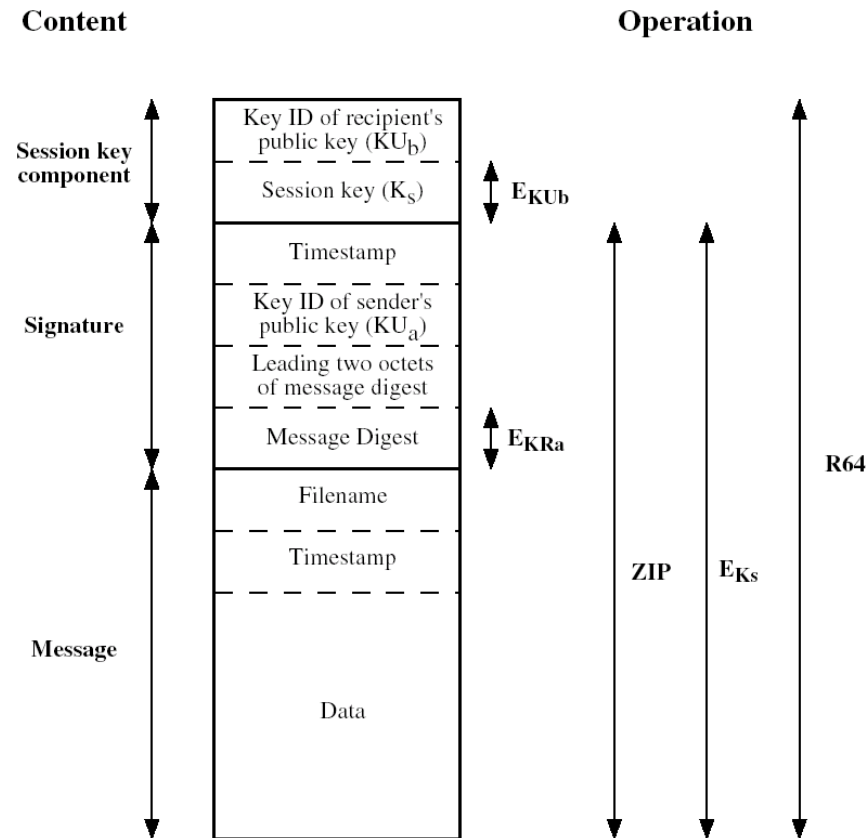
Broad range of algorithms supported:

- ▶ Symmetric encryption:
 - DES, 3DES, AES and others.
- ▶ Public key encryption of session keys:
 - RSA or ElGamal.
- ▶ Hashing:
 - SHA-1, MD-5 and others.
- ▶ Signature:
 - RSA, DSS, ECDSA and others.

PGP Services



PGP Message



PGP Key Rings

- ▶ PGP supports multiple public/private keys pairs per sender/recipient.
- ▶ Keys stored locally in a *PGP Key Ring* – essentially a database of keys.
- ▶ Private keys stored in encrypted form; decryption key determined by user–entered pass–phrase.

Key Management for PGP

- ▶ Public keys for encrypting session keys / verifying signatures.
- ▶ Private keys for decrypting session keys / creating signatures.
- ▶ Where do these keys come from and on what basis can they be trusted?

PGP Key Management

- ▶ PGP adopts a trust model called the *web of trust*.
- ▶ No centralised authority
- ▶ Individuals sign one another's public keys, these "certificates" are stored along with keys in key rings.
- ▶ PGP computes a *trust level* for each public key in key ring.
- ▶ Users interpret trust level for themselves.

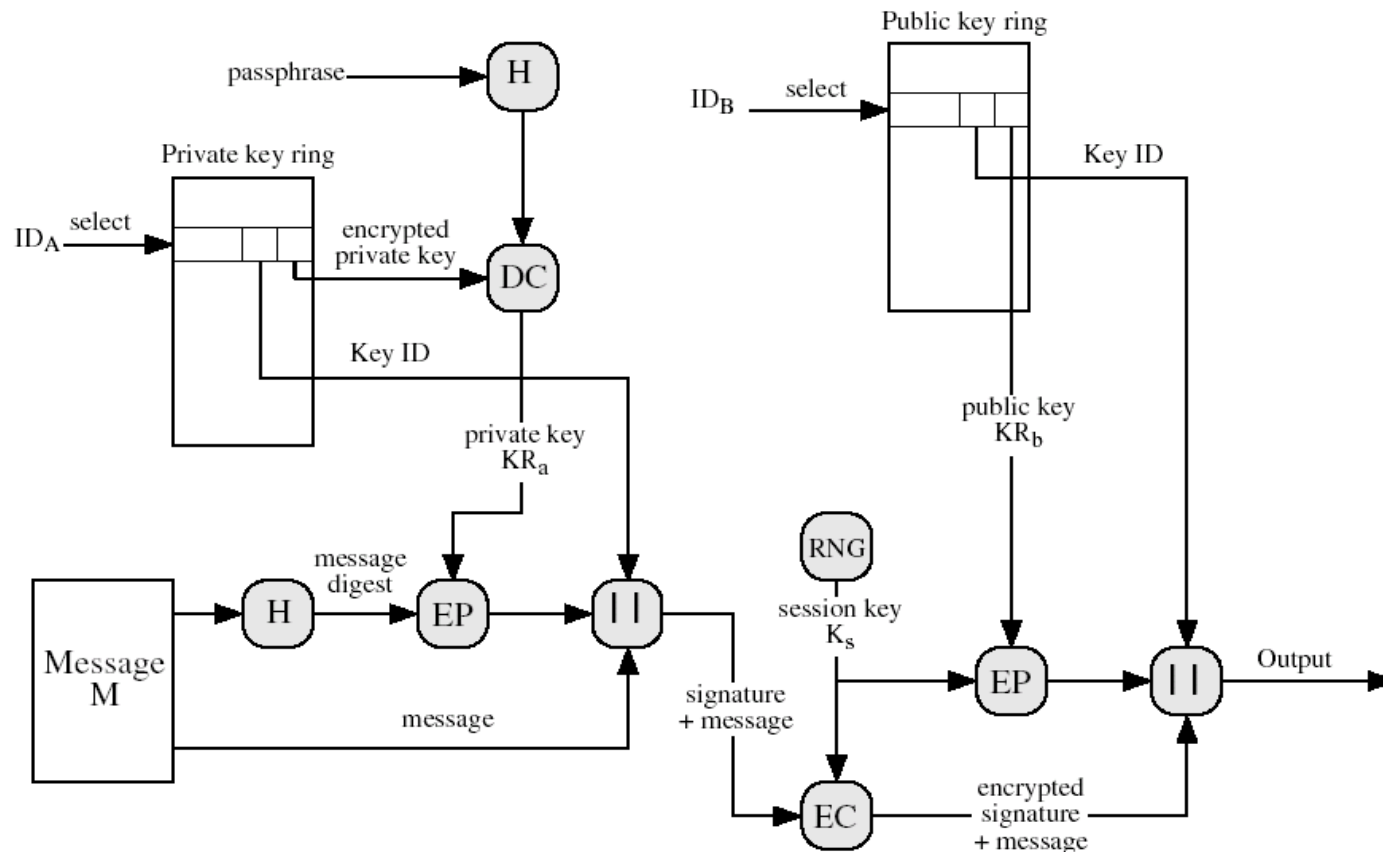
PGP Trust Levels

- ▶ Trust levels for public keys dependent on:
 - Number of signatures on the key;
 - Trust level assigned to each of those signatures.
- ▶ Trust levels recomputed from time to time.

PGP Key Mgmt Issues

- ▶ Original intention was that all e-mail users would contribute to web of trust.
- ▶ Reality is that this web is sparsely populated.
- ▶ How should security-unaware users assign and interpret trust levels?
- ▶ Later versions of PGP support X.509 certs.

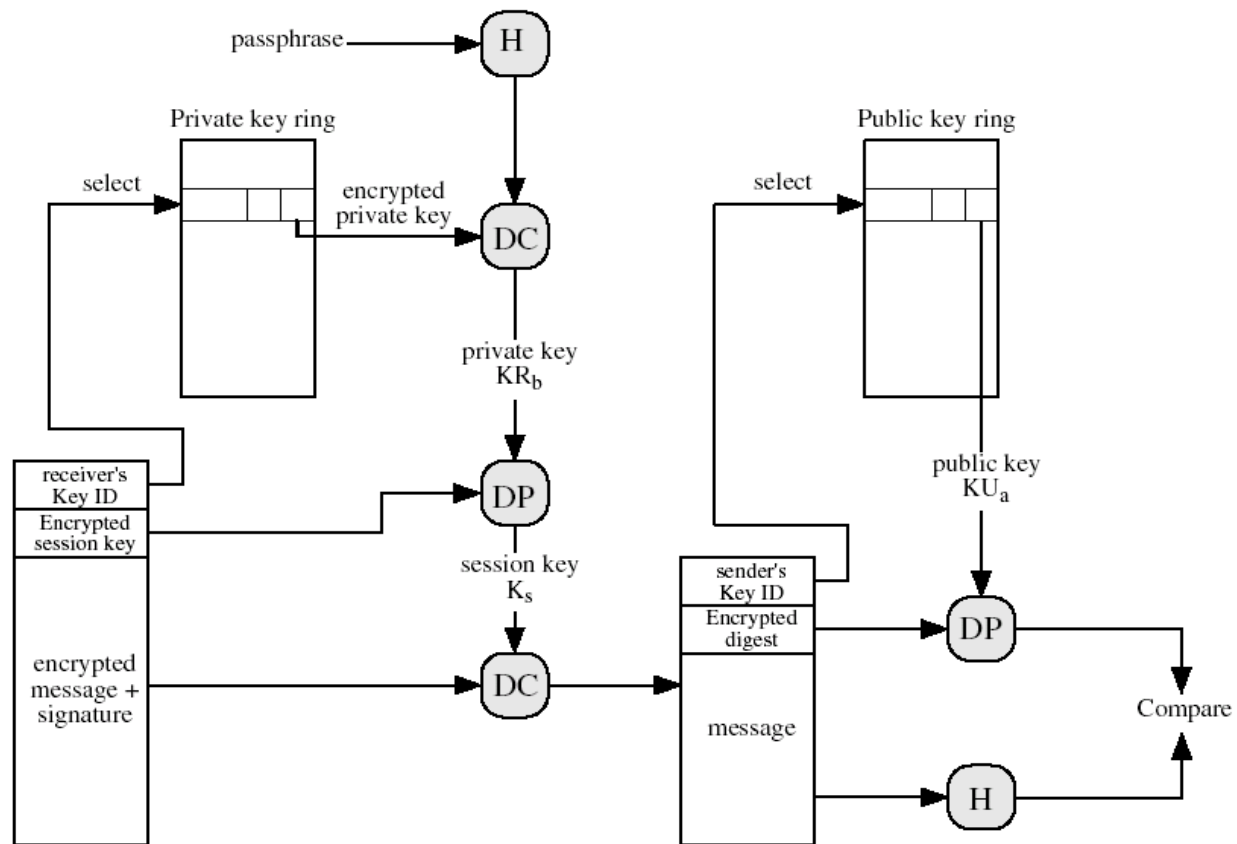
PGP Message Generation



PGP Message Generation (cont'd)

- ▶ The sending PGP entity performs the following steps:
 - Signs the message:
 - PGP gets sender's private key from key ring using its user id as an index.
 - PGP prompts user for passphrase to decrypt private key.
 - PGP constructs the signature component of the message.
 - Encrypts the message:
 - PGP generates a session key and encrypts the message.
 - PGP retrieves the receiver public key from the key ring using its user id as an index.
 - PGP constructs session component of message

PGP Message Reception



PGP Message Reception

- ▶ The receiving PGP entity performs the following steps:
 - Decrypting the message:
 - PGP get private key from private-key ring using Key ID field in session key component of message as an index.
 - PGP prompts user for passphrase to decrypt private key.
 - PGP recovers the session key and decrypts the message.
 - Authenticating the message:
 - PGP retrieves the sender's public key from the public-key ring using the Key ID field in the signature key component as index.
 - PGP recovers the transmitted message digest.
 - PGP computes the message for the received message and compares it to the transmitted version for authentication.

Concept of Secure Email

- ▶ Email security refers to the collective measures used to secure the access and content of an email account or service. It allows an individual or organization to protect the overall access to one or more email addresses/accounts.
- ▶ An email service provider implements email security to secure subscriber email accounts and data from hackers – at rest and in transit.

- ▶ Email security is a broad term that encompasses multiple techniques used to secure an email service. From an individual/end user standpoint, proactive email security measures include:
 - Strong passwords
 - Password rotations
 - Spam filters
 - Desktop-based anti-virus/anti-spam applications
- ▶ Similarly, a service provider ensures email security by using strong password and access control mechanisms on an email server; encrypting and digitally signing email messages when in the inbox or in transit to or from a subscriber email address. It also implements firewall and software-based spam filtering applications to restrict unsolicited, untrustworthy and malicious email messages from delivery to a user's inbox.

Assignment 8

1. Describe the threats to the security of email itself.
2. Compare between TLS and SSL.
3. Explain the architecture of SSL with its components.
4. Explain the protocols of TLS.
5. Explain the process of secure electronic transaction (SET) with necessary block diagram.
6. Explain about the construction and operation dual signature.
7. Explain processes for PGP message generation and reception.
8. Write short notes on:
 1. Simple Mail Transfer Protocol (SMTP)
 2. Privacy Enhanced Mail (PEM)
 3. PGP Key Ring
 4. Secure email